Cybersecurity Engineering & Managed Security Department Handbook

Training, authorised assessment, hardening and client delivery: from first day to professional practice

Developed by **V. LOKESHWARAN**
VEL Software Solutions
velsoftwaresolutions.in@gmail.com

Document VEL-CS-001 · Version 1.0 (draft for management approval) · 4 November 2026

Defensive and authorised use only. Every activity in this handbook must be owned, authorised, scoped and documented. Nothing here permits scanning, testing or accessing a system without written permission from its owner.

Contents

VEL Cybersecurity Department Handbook 4
- 0.1 What this handbook is 4
- 0.2 What is in Module 1 (this edition) 4
- 0.3 How to use it 4
- 0.4 The twelve golden rules 5

Part 1 — Department Charter and Service Portfolio 6
- 1.1 Mission and operating principles 6
- 1.2 Service portfolio 6
- 1.3 What we will not do 7
- 1.4 Department structure and reporting 7
- 1.5 Management decisions needed before launch 7

Part 2 — Team Structure and Employee Responsibility Matrix 8
- 2.1 Roles 8
- 2.2 The authority ladder (what each person may do alone) 8
- 2.3 RACI matrix: client lifecycle 9
- 2.4 Who approves what (approval register) 10
- 2.5 Separation of duties 10

Part 3 — Authorised Testing Policy (POL-SEC-001)
- 3.1 Purpose and principles 11
- 3.2 Definitions 11
- 3.3 Mandatory preconditions (the "no-go until" list) 11
- 3.4 Testing is not allowed if... 12
- 3.5 Risk tiers of testing activity 12
- 3.6 Mandatory safe-testing practice 13
- 3.7 Prohibited actions (regardless of who asks) 14
- 3.8 Stop-work conditions 14
- 3.9 Evidence and data handling 14
- 3.10 Training and lab rule 15
- 3.11 Disclosure, incidents and breach of policy 15
- 3.12 Acknowledgement 15
- 3.13 Rules of Engagement: required contents 15

Part 4 — Beginner Onboarding Programme 17
- 4.1 Programme at a glance 17
- 4.2 Pre-boarding checklist (HR / PM) 17
- 4.3 Week 1 day-by-day plan 18
- 4.4 Code of Ethics (sign on Day 1) 18
- 4.5 Secure workstation baseline 18
- 4.6 Accounts and access (least privilege) 19
- 4.7 Mentor, supervision and probation 19
- 4.8 Week 1 sign-off sheet 20

Part 5 — 90-Day Training Roadmap 21
- 5.1 Roadmap overview 21
- 5.2 Week-by-week plan 21
- 5.3 Weekly rhythm 22
- 5.4 Gates and assessment standards 23
- 5.5 Rubric for practical work (score 0–4 per criterion) 23
- 5.6 Training project schedule and approvals 23

5.7 After day 90: continuing professional growth 24

Part 6 — Teaching Format and Module Catalogue 25

6.1 The 14-point teaching format 25
6.2 Sample module M-L2-04: Linux accounts, permissions and SSH hardening 25
6.3 Sample module M-L6-02: Nmap: safe, authorised network discovery 26
6.4 Sample module M-L6-05: Secret scanning with Gitleaks 27
6.5 Module catalogue (Levels 1–7) 28

Part 7 — Client Engagement Lifecycle (Stages 01–15) 31

7.1 Stage map 31
7.2 Asset inventory fields 32
7.3 Repository and documentation structure 32
7.4 Finding record and rating 32
7.5 Final report outline 33
7.6 Managed security: what is and is not included 34

Part 8 — Security Incident Response 35

8.1 The six phases 35
8.2 Severity levels (suggested defaults) 35
8.3 Escalation procedure 36
8.4 Evidence preservation 36
8.5 Client notification responsibilities 36
8.6 Incidents during an engagement 37
8.7 Tabletop exercise 01 (Training Week 8) 37

Part 9 — Lab 01: Isolated Linux Server Hardening Lab 38

9.1 Objectives and learning outcomes 38
9.2 Lab topology 38
9.3 Prerequisites and tool register 39
9.4 Phase A: Authorise and isolate (Day 1) 39
9.5 Phase B: Baseline (Day 2) 39
9.6 Phase C: Hardening controls H1–H10 (Days 2–4) 40
9.7 Phase D: Verify and compare (Day 5) 44
9.8 Common mistakes and troubleshooting 45
9.9 Deliverables: the Lab 01 hardening report 45
9.10 Assessment and approvals 46

Appendices 47

Appendix A: Official sources and references 47
Appendix B: Glossary 48
Appendix C: Ready-to-copy templates 49
Appendix D: Beginner quick-reference card 50
Appendix E: What comes next (module plan) 51
Appendix F: Document approval and revision history 52

VEL Cybersecurity Department Handbook

Cybersecurity Engineering & Managed Security Department: Module 1 (Foundation Pack)

Document ID	VEL-CS-001
Version	1.0 (draft for management approval)
Owner	V. LOKESHWARAN, Founder (acting Security Lead until one is appointed)
Audience	Beginner and junior security staff, project managers, QA reviewers, and management
Review cycle	Every quarter, after any security incident, and after any change in law or client contract terms
Companion document	VEL Delivery Handbook (VEL-DH-001): general software delivery procedure
Contact	velsoftwaresolutions.in@gmail.com

0.1 What this handbook is

This handbook sets up a professional cybersecurity services department inside VEL Software Solutions. It tells every employee **what the department does, who may do what, how beginners are trained, and how a client engagement runs from first call to handover**. It is written for people who start with basic IT knowledge and must become safe, effective defenders.

It is delivered **one module at a time**, because quality and legal safety matter more than speed. This first module contains the six items needed before any security work begins.

0.2 What is in Module 1 (this edition)

#	Deliverable	Where
1	**Cybersecurity Department Handbook**	Parts 1, 7 and 8: charter, service portfolio, 15-stage client lifecycle, incident response
2	**Beginner onboarding programme**	Part 4
3	**Employee responsibility matrix**	Part 2 (roles, authority ladder, RACI)
4	**90-day training roadmap**	Part 5, with the teaching format and sample modules in Part 6
5	**Authorised testing policy**	Part 3 (policy, tiers, authorisation pack, stop-work rules)
6	**First isolated security lab**	Part 9: Linux Server Hardening Lab (Training Project 1)

Appendices hold the official sources, glossary, ready-to-copy templates, the sign-off sheet and the plan for the next modules.

0.3 How to use it

1. Read **Part 3 (Authorised Testing Policy)** and sign the acknowledgement **before touching any tool**.
2. Follow Part 4 for your first week, then the 90-day roadmap in Part 5.
3. Check Part 2 to learn what you may do alone, what needs approval, and what you must never do.
4. When a client project starts, work through the stages in Part 7 in order and do not skip a gate.

5. If you are unsure, **stop and ask** your Security Lead. Stopping is never a mistake; guessing about authorisation is.

0.4 The twelve golden rules

1. **No written authorisation, no testing.** Verbal permission, a friendly email, or "it is our own client's website" is not authorisation.
2. **Stay inside the scope.** Only the exact targets, methods and time window written in the Rules of Engagement.
3. **Practise only in owned or intentionally vulnerable labs.** Learning never happens on real third-party systems.
4. **Beginners do not perform high-risk testing alone** and never approve their own critical findings.
5. **Do no harm.** Prefer the least intrusive method that answers the question. Back up before changing anything.
6. **Stop first, explain later** if something unexpected happens: an outage, real customer data, signs of a real attacker.
7. **Verify before you report.** A scanner alert is a lead, not a finding.
8. **Protect evidence and client data.** Encrypt it, minimise it, never put it in an ordinary Git repository.
9. **Tell the truth in reports.** No exaggeration, no hidden limitations, no invented certainty.
10. **Never claim what we do not hold.** No certification, audit authority, "guaranteed secure", 24/7 SOC or structural-style safety claims we cannot back up.
11. **Never make legal decisions.** Breach notification and legal interpretation belong to the client and qualified legal or compliance specialists.
12. **Write it down.** If it is not in a ticket, a log or a document, it did not happen.

IMPORTANT LEGAL NOTICE

This handbook is an internal operating procedure, not legal advice. Laws on computer misuse, data protection and incident reporting differ by country and change over time. The department must confirm applicable requirements with qualified legal counsel (for India this includes the Information Technology Act, 2000, the Digital Personal Data Protection Act, 2023, and CERT-In directions) before offering services or signing client contracts. Items marked *"suggested default"* are proposals for management approval.

CLAIMS POLICY

VEL does not claim certification, independent-audit authority, accreditation, or 24/7 monitoring unless the company and named personnel actually hold the credentials and have the staffing and systems to deliver. Every proposal, website line and report must be checked against this rule by the Security Lead.

Part 1 — Department Charter and Service Portfolio

1.1 Mission and operating principles

Mission: help clients find, understand and reduce security risk through authorised, documented, defensive security work, delivered by well-trained people working under qualified supervision.

Principle	What it means in daily work
Authorised only	Every test, scan and access has a signed authorisation and a defined scope.
Defensive purpose	We find weaknesses so they can be fixed. We do not build or deploy attack tools against third parties.
Least intrusive method	Configuration review before scanning; scanning before manual verification; manual verification only where safe.
Supervised growth	Authority is earned through training, assessment and observed practice (the authority ladder in Part 2).
Evidence-based	Findings are confirmed, reproducible within scope, and backed by sanitised evidence.
Honest limits	Reports state what was and was not tested, and what we cannot conclude.
Client data is sacred	Minimise, encrypt, restrict, retain only as agreed, then securely delete.

1.2 Service portfolio

Services are grouped A to F. A service may be sold only when the delivering team has the trained people, tools and approvals listed in Part 2 and Part 3.

Category	Services	Delivery notes and limits
A. Security Assessment	Website, web application, API, cloud configuration, network and infrastructure assessments; vulnerability assessment; security posture assessment	Written authorisation and agreed rules of engagement first. Findings verified manually where safe. Report states limitations.
B. Security Hardening	Linux and Windows server hardening; cloud hardening; database security; firewall configuration; IAM; MFA; secure configuration management	Back up configuration first; test in staging; change approved by client owner; rollback plan written.
C. Application Security	Secure code review; OWASP Top 10 assessment; authentication, authorisation and session reviews; dependency scanning; SAST; DAST; software composition analysis	DAST against staging by default. Production testing needs separate approval (Tier 2 or higher, Part 3).
D. Cloud Security	AWS, Azure and GCP assessments; IAM review; storage and network security; secrets management; audit logging; compliance readiness	Read-only audit roles. We never ask for owner or root credentials. "Readiness" is not certification.
E. Managed Security	Continuous monitoring, vulnerability and patch management, security alerts, configuration reviews, incident response support, reporting	Defined hours, alert volumes and response targets in contract. **No 24/7 SOC claim** without staffing and systems to deliver it.

Category	Services	Delivery notes and limits
F. Governance & Compliance	Security policies, risk registers, asset inventories, access reviews, vendor assessments, audit preparation, ISO 27001 readiness, privacy process support	"Readiness support" only. VEL does not certify, and does not act as an independent auditor unless properly accredited.

1.3 What we will not do

- Scan, test, log in to, or probe any system we do not have written authority to test.
- Run credential attacks, malware deployment, denial-of-service, social engineering or physical intrusion unless management has formally added that service (with legal and insurance review) and the client has authorised that exact activity in writing (Tier 3).
- Access, copy or keep more client data than the assessment needs.
- Sell "guaranteed secure" or "unhackable" outcomes. No assessment proves the absence of vulnerabilities.
- Make legal decisions, including whether a breach must be notified to a regulator.

1.4 Department structure and reporting

Function	Roles	Reports to
Leadership and quality	Security Lead; QA Reviewer	Founder / management
Assessment and engineering	Security Consultant; Application Security Engineer; Cloud Security Engineer	Security Lead
Operations	SOC Analyst; Security Analyst (entry level)	Security Lead
Delivery management	Project Manager	Founder (dotted line to Security Lead)

SMALL-TEAM NOTE

In a startup one person may fill several roles. Duties still exist separately. **Independence rule:** the person who writes a critical finding must not be the only person who approves it, and nobody approves their own work.

1.5 Management decisions needed before launch

#	Decision	Owner
1	Appoint an accountable Security Lead (internal or external senior adviser)	Founder
2	Confirm professional indemnity / cyber liability insurance covers security testing services	Founder + insurer
3	Approve standard contract templates (MSA, SoW, testing authorisation, NDA, data processing terms) reviewed by counsel	Founder + legal
4	Approve this policy set (Part 3) and the Code of Ethics (Part 4)	Founder
5	Decide which services are in the launch portfolio (suggested: A, B, C and F first; E after staffing is proven)	Founder + Security Lead
6	Fund approved lab hardware, licences and encrypted evidence storage	Founder

Part 2 — Team Structure and Employee Responsibility Matrix

2.1 Roles

Role	Mission	Typical responsibilities
Security Analyst entry level	Learn and support: collect, document and triage under supervision	Asset inventory, evidence handling, scanner runs within approved tiers, draft findings, lab work, documentation
Application Security Engineer	Secure the software layer	OWASP Top 10 reviews, code review, SAST/DAST/SCA setup and triage, auth and session reviews, API checks, secure-coding guidance
Cloud Security Engineer	Secure cloud accounts and infrastructure	AWS/Azure/GCP configuration review, IAM, storage, network, secrets, logging, hardening implementation
Security Consultant	Own the client engagement technically	Qualification, scope, methodology, threat modelling, finding validation, client briefings, report authorship
SOC Analyst	Monitor and respond	Alert triage, log review, vulnerability tracking, patch verification, incident coordination, monthly reports
QA Reviewer	Independent quality check	Reviews authorisation completeness, evidence integrity, finding accuracy, report quality, retest results
Security Lead	Accountable for safety, quality and legality	Approves scope, tiers, critical findings and reports; owns policies; signs training gates; escalation point
Project Manager	Deliver on time and within agreement	Client communication, schedule, change control, invoices, stop-work coordination, handover

2.2 The authority ladder (what each person may do alone)

Authority depends on **demonstrated competence**, not job title. Each level is granted in writing by the Security Lead after the gates in Part 5.

Level	Name	May do	Must not do
A0	Trainee	Learn and practise **only** in the owned isolated lab (Part 9) and intentionally vulnerable training apps. Write documentation. Shadow engagements as observer.	Touch any client system, even read-only. Run any scan on a non-lab network.
A1	Supervised junior	On an authorised engagement, **with a named senior present or reviewing live**: Tier 0 and Tier 1 work (Part 3). Draft findings.	Tier 2 or 3 testing. Close or rate Critical/High findings. Contact the client technically without the Consultant.
A2	Practitioner	Tier 0 and 1 independently; Tier 2 inside an approved window with written approval from Security Lead. Own findings drafts and hardening tasks.	Tier 3. Approve their own Critical/High findings. Change scope.

Level	Name	May do	Must not do
A3	Senior / Lead	Recommend and run Tier 3 only where management has enabled the service and the client has specifically authorised it. Approve findings, reports, scope.	Operate outside contracted scope. Make legal notification decisions.

HARD RULE

A beginner (A0 or A1) must **never independently perform high-risk security testing** and must **never approve their own critical findings**. Critical and High findings need a second person (Consultant or Security Lead) to confirm before the client sees them.

2.3 RACI matrix: client lifecycle

R = does the work · **A** = accountable, approves (exactly one per row) · **C** = consulted · **I** = informed · "—" = not involved. The client's authorised signatory is outside this table but must sign the authorisation.

Stage / activity	Analyst	AppSec	Cloud	Consult.	SOC	QA	Sec Lead	PM
01 Client qualification	—	—	—	**R**	—	—	**A**	**R**
02 Written authorisation	I	I	I	**R**	—	C	**A**	**R**
03 Security discovery	**R**	**R**	**R**	**A**	C	I	C	I
04 Asset inventory	**R**	C	C	**A**	C	C	I	I
05 Threat model & risk assessment	C	**R**	**R**	**R**	C	C	**A**	I
06 Scope & cost approval	I	C	C	**R**	I	C	**A**	**R**
07 Assessment environment	**R**	C	C	**A**	C	C	I	I
08 Repository & documentation	**R**	C	C	**A**	I	C	I	C
09 Security testing (authorised tiers)	**R***	**R**	**R**	**A**	C	I	C	I
10 Vulnerability classification	**R***	**R**	**R**	**R**	I	C	**A**	I
11 Security hardening	**R***	**R**	**R**	**A**	C	C	C	I
12 Security QA	I	C	C	C	I	**R**	**A**	I
13 Reporting	**R***	C	C	**R**	I	C	**A**	C
14 Client handover	I	I	I	**R**	I	I	**A**	**R**
15 Managed security (monthly)	**R***	C	C	C	**R**	C	**A**	**R**
Cross-cutting								
Incident response (Part 8)	C	C	**R**	**R**	**R**	I	**A**	**R**
Stop-work decision	**R**	**R**	**R**	**R**	**R**	**R**	**A**	C
Training & authority-ladder changes	C	C	C	**R**	C	C	**A**	**R**
Policy maintenance	C	C	C	**R**	C	**R**	**A**	I

* Analysts act at level A0/A1 only: supervised, within Tier 0–1, drafts only. **Stop-work:** every person has the right and duty to stop; the Security Lead is accountable for the decision to resume.

2.4 Who approves what (approval register)

Item	Prepared by	Approved by	Second person
Rules of Engagement and authorisation pack	Consultant	Security Lead + client signatory	QA Reviewer
Tier 2 test window	Engineer	Security Lead	PM (client notice)
Tier 3 activity	Consultant	Security Lead + client + management	Legal advice on file
Critical / High finding	Any author	Security Lead	Consultant (not the author)
Hardening change	Engineer	Client system owner	Consultant; rollback plan reviewed
Final report	Consultant	Security Lead	QA Reviewer
Authority-ladder promotion	Consultant (mentor)	Security Lead	Founder (record)
Client breach / legal notification	—	**Client and their counsel**	VEL escalates only

2.5 Separation of duties

- Authors do not approve their own Critical or High findings or reports.
- The person who performs a hardening change is not the sole verifier of that change.
- Access to client evidence is granted per engagement, reviewed monthly, and removed at close-out.
- Administrative access to VEL's evidence store is held by the Security Lead and one named deputy only.

Part 3 — Authorised Testing Policy (POL-SEC-001)

Policy ID	POL-SEC-001 · Version 1.0 · effective on management approval
Applies to	All VEL employees, contractors and trainees who perform or support security assessment, scanning, testing, hardening or monitoring
Policy owner	Security Lead · approved by Founder
Breach of policy	May result in disciplinary action, termination and legal liability. Unauthorised access to computer systems can be a criminal offence.

THE ONE-SENTENCE POLICY

We test, scan or access **only** systems that the owner has authorised **in writing**, **only** the targets, methods and times named in that authorisation, and **only** by people whose authority level permits the activity.

3.1 Purpose and principles

1. **Legality:** security testing without permission can break criminal and civil law, even with good intentions.
2. **Safety:** testing can slow, crash or corrupt systems and expose personal data. The client's business comes first.
3. **Proportionality:** use the least intrusive method that answers the question.
4. **Accountability:** every action can be traced to a person, an approval and a record.

3.2 Definitions

Term	Meaning
Authorised testing	Testing covered by a signed agreement, asset ownership confirmation and written test authorisation naming exact scope, methods and window.
Scope / in-scope	The exact systems (identifiers) listed in `approved-targets.csv`. Anything not listed is out of scope.
Rules of Engagement (RoE)	The signed document that states permitted methods, exclusions, time window, contacts and stop-work conditions.
Owned lab	A VEL-owned, network-isolated environment built for training (for example Part 9). Includes intentionally vulnerable applications run locally.
Stop-work condition	An event that halts all testing immediately until the Security Lead and client contact agree to resume.
Production / staging	The live system real users depend on / a safe copy used for trials. Staging is preferred for anything active.

3.3 Mandatory preconditions (the "no-go until" list)

No scan, probe, login or test of a client system may start until **every** item is complete and filed. The QA Reviewer checks the pack before the Security Lead releases the "Authorised to start" marker.

	Item	Requirement
☐	**1. Signed agreement**	MSA/SoW signed by an authorised signatory of the client; confidentiality and data handling terms included.
☐	**2. Asset ownership confirmation**	Client confirms in writing that it owns or has authority to authorise testing of every target. Third-party hosting, SaaS, cloud and managed providers: their testing rules are checked and, where needed, their permission obtained.
☐	**3. Written testing authorisation**	Names VEL, named testers, purpose and duration; signed and dated.
☐	**4. Exact target scope**	Domains, IPs/ranges, applications, API endpoints, cloud account IDs, environments: no wildcards without written agreement.
☐	**5. Permitted test methods**	Listed by tier (3.5). Anything not listed is not permitted.
☐	**6. Excluded systems**	Systems, data, networks and methods that are off-limits (e.g. payment processors, safety-critical systems, third-party SaaS).
☐	**7. Testing time window**	Start/end date and time with time zone; blackout periods (month-end, sales events).
☐	**8. Emergency contact**	24-hour reachable named client contact with phone number, plus VEL on-call lead.
☐	**9. Stop-work conditions**	Agreed list (3.8) and who can invoke it.
☐	**10. Data handling agreement**	What data may be viewed, copied, stored, where, for how long; how it is deleted; who may access it.
☐	**11. Backups and rollback**	Client confirms current backups for any system to be changed; rollback plan agreed.
☐	**12. Tester authority check**	Each tester's authority level (A0–A3) covers the tiers approved.

3.4 Testing is not allowed if...

- the target is not on the approved list, even if it "looks like" the client's;
- the authorisation is expired, unsigned, or signed by someone without authority over the asset;
- the target is run by a third party who has not agreed (cloud provider rules, SaaS vendors, shared hosting neighbours);
- a stop-work condition is active; or
- you are unsure. **Uncertainty is a stop, not a green light.**

3.5 Risk tiers of testing activity

Tier	Examples (all in-scope and authorised)	Minimum authority	Extra approval
T0 Passive	Document and policy review; architecture review; reviewing client-provided exports, configs, diagrams, logs (sanitised)	A1 (supervised)	None beyond authorisation pack

Tier	Examples (all in-scope and authorised)	Minimum authority	Extra approval
T1 Low-impact active	SAST and dependency/secret scanning on provided code; image scanning; read-only cloud configuration audit using a read-only role; TLS/header checks of in-scope sites; authenticated read-only configuration checks	A1 (senior present) / A2 independent	Consultant confirms tool settings before run
T2 Moderate active	Network vulnerability scanning in agreed window; DAST/web scanning of **staging**; authenticated application testing with test accounts; manual verification of a scanner finding when safe	A2	Written approval from Security Lead per window; client notified; rate limits set; monitoring contact on call
T3 High risk	Testing in production with active scanning; verification that could alter data or availability; anything involving credentials against live systems; social-engineering or physical elements; load or stress effects	A3 only; **never trainees**	Written client authorisation naming the exact activity, Security Lead + management approval, legal advice on file, enabled service
Prohibited	Denial-of-service, malware deployment, credential attacks on third parties, data exfiltration beyond minimal proof, persistence, pivoting outside scope, testing of unconfirmed owners	Nobody	Not offered by the department

3.6 Mandatory safe-testing practice

1. **Re-read the RoE** at the start of each session; confirm the date, window and target list.
2. **Verify the target** against `approved-targets.csv`; check IP/domain ownership before running a tool. DNS can change.
3. **Choose the gentlest tool setting.** Set rate limits and thread counts; exclude dangerous checks (e.g. destructive or denial-of-service plugins).
4. **Use a recorded, approved workstation** (Stage 07): encrypted disk, MFA, logging, tool versions recorded.
5. **Log every run:** who, what, command/settings, target, start/end time, result file name.
6. **Verify manually only where safe** and permitted; stop at the minimum proof needed. Do not read, copy or modify real customer data beyond what the RoE allows.

7. **Handle credentials correctly:** use test accounts; store in the approved password manager; never reuse; never place in tickets, chats or repositories.
8. **Report promptly:** a Critical finding that is actively exploitable or exposes personal data is reported to the Security Lead immediately, then to the client contact the same day through the agreed channel.
9. **Clean up:** remove test accounts, uploaded files and scan artefacts as agreed; confirm in writing.

3.7 Prohibited actions (regardless of who asks)

	Never
×	Test a system for "practice" or "to impress" without written authority, including your former employer, friends' sites, public bug-bounty targets outside their published programme rules, or government/critical infrastructure.
×	Run unreviewed scripts, exploits or tools downloaded from the internet on a client system or on the company network.
×	Guess, brute-force or reuse passwords on accounts you were not given for the test.
×	Deploy malware, backdoors or persistence mechanisms on any client system.
×	Access, download or share real customer personal data beyond the minimum evidence agreed.
×	Exceed the time window, rate limits or methods in the RoE; or continue after a stop-work call.
×	Disclose vulnerabilities to anyone but the authorised client contacts and VEL's named reviewers.
×	Commit evidence, passwords, tokens, client data or exploitable detail to an ordinary Git repository, personal drive, messaging app or AI chat tool.

3.8 Stop-work conditions

Stop **all active testing at once** (do not "just finish this one request"), preserve notes, and call the Security Lead. The Security Lead informs the client's emergency contact.

- Target slows, errors, or becomes unavailable during testing.
- You discover a target not on the list, or the owner of a target is not the client.
- You encounter personal, financial or health data not covered by the data handling agreement.
- You find signs of a real attack or prior compromise (unknown accounts, unexpected processes, webshells).
- The client contact or VEL lead calls stop, or the time window ends.
- A tool behaves unexpectedly (sends traffic you did not intend).
- A legal, safety or contractual doubt arises.

3.9 Evidence and data handling

- Collect the **minimum** evidence that proves the issue: sanitised screenshots, truncated logs, configuration excerpts. Mask secrets, tokens and personal data.
- Store evidence only in the approved, access-controlled, encrypted store. Record a SHA-256 hash and collection time for important items.
- Retain and delete according to the signed data handling agreement and `policies/retention.md`; record deletion.

- Reports for executives must not contain unnecessary exploit detail. Technical detail goes in a restricted annex with need-to-know access.

3.10 Training and lab rule

All practice for learning, tool testing or demonstrations uses **owned or intentionally vulnerable environments**, built on an isolated network (Part 9), with a signed *Lab Authorisation Record* (Appendix C). Intentionally vulnerable apps (for example OWASP Juice Shop) are run **locally** and never exposed to the internet or company LAN. Training skills are never tried on "real" targets.

3.11 Disclosure, incidents and breach of policy

- Vulnerabilities found are disclosed only to the client's authorised contact via the agreed secure channel.
- Accidental out-of-scope contact (for example a mistyped IP) is reported to the Security Lead **immediately**, with exact time and action. Honest early reporting is protected; concealment is a serious breach.
- Policy violations are investigated by the Security Lead and Founder. Outcomes range from retraining to dismissal and, where required, legal reporting.

3.12 Acknowledgement

I have read and understood POL-SEC-001. I will not test, scan or access any system without written authorisation, and I will stop and ask if I am unsure.

Name	Role / level	Signature	Date

3.13 Rules of Engagement: required contents

#	Section	What it must state
1	Parties & authority	Legal names, signatories, VEL testers (names and levels)
2	Objectives	What questions the assessment answers and what is not being assessed
3	In-scope assets	Table copied from `approved-targets.csv`, with owner and environment
4	Out-of-scope assets	Named exclusions, third-party services, data stores
5	Permitted methods	By tier; rate limits; tools and settings; credentials provided
6	Time window	Dates, hours, time zone, blackout periods, source IPs used by VEL
7	Contacts	Primary, emergency (24h), escalation; communication channels
8	Stop-work & escalation	Conditions (3.8), who can invoke, restart procedure
9	Data handling	Data types, storage, encryption, retention, deletion, sub-processors
10	Reporting	Report type, delivery, severity method, retest terms
11	Liability & legal	Reviewed by counsel; third-party permissions attached

#	Section	What it must state
12	Signatures	Client authorised signatory, VEL Security Lead, dates

Sample `approved-targets.csv` (documentation addresses only)

```
target_id,type,identifier,environment,owner,tier_max,window_start,window_end,notes
T-001,web_app,https://staging.example.com,staging,Client IT Head,T2,2026-12-01T09:00+05:30,2026-12-05T18:00+05:30,test accounts provided
T-002,host,192.0.2.10,staging,Client IT Head,T2,2026-12-01T09:00+05:30,2026-12-05T18:00+05:30,Linux app server
T-003,api,https://api-staging.example.com/v1,staging,Client App Owner,T1,2026-12-01T09:00+05:30,2026-12-05T18:00+05:30,read-only token
X-001,excluded,https://pay.example-gateway.com,production,Third party,NONE,,,"payment provider - EXCLUDED"
```

`example.com` and `192.0.2.0/24` are reserved for documentation (RFC 6761 and RFC 5737). Real engagements use the client's actual identifiers.

Part 4 — Beginner Onboarding Programme

Goal: in the first week every new employee is **legally briefed, equipped with a secure workstation, assigned a mentor, and able to practise safely** in the isolated lab. Technical depth comes later (Part 5). Trust comes before tools.

4.1 Programme at a glance

Stage	Outcome	Key activities	Owner
Pre-boarding (before Day 1)	Contractually and legally ready	Signed employment terms, NDA, acceptable-use policy, code of ethics; identity and eligibility checks as permitted by law	PM + Founder
Day 1	Welcomed, briefed, equipped	Company and department tour; mentor assigned; accounts created with least privilege; workstation baseline	PM + Mentor
Days 2–3	Understands the legal line	Authorised Testing Policy (Part 3) workshop; legal and ethics quiz; case studies of unauthorised-testing consequences	Security Lead
Days 4–5	Can work in the lab safely	Virtualisation setup; isolated lab network; first snapshot and rollback; evidence and note-taking habits	Mentor
Week 2	Enters the 90-day roadmap	Starts Level 1 modules; weekly 1:1; progress tracker opened	Mentor
Day 30 / 60 / 90	Gated progression	Written and practical assessments; authority level reviewed	Security Lead

4.2 Pre-boarding checklist (HR / PM)

	Item	Evidence
☐	Employment or contractor agreement signed, including confidentiality and intellectual-property terms	Signed copy in HR file
☐	Non-disclosure agreement and Acceptable Use Policy signed	Signed copies
☐	Code of Ethics (4.4) read and signed	Signed copy
☐	Identity and eligibility verification per applicable law; background checks only as lawful and proportionate	HR record
☐	Mentor ("buddy") named, introduction email sent with Day 1 agenda	Email
☐	Workstation ordered or prepared (see 4.5); no real client data on it	Asset record

4.3 Week 1 day-by-day plan

Day	Morning	Afternoon	Output / sign-off
1	Welcome; company, services, department structure (Part 1–2); meet mentor	Accounts and MFA; password manager; workstation baseline (4.5)	Baseline checklist signed by Mentor
2	Why security testing is legal only with authorisation; real-world cases; Authorised Testing Policy read-through	Rules of Engagement and scope exercises on paper (identify in-scope/out-of-scope from sample documents)	Exercise answers reviewed
3	Data protection basics; evidence and data handling; reporting and escalation	Legal and ethics quiz (**100% pass mark**; retake after coaching); policy acknowledgement signed	Quiz record + signed POL-SEC-001
4	Virtualisation basics; install hypervisor; create isolated host-only network	Build a blank test VM; snapshot; rollback exercise	Lab isolation check (Part 9, Phase A)
5	Note-taking, documentation templates, tickets, Git for documentation (no secrets)	Week review with mentor; plan weeks 2–4; **Lab Authorisation Record** signed by Security Lead	Week 1 sign-off (4.8)

WHY LEGAL TRAINING COMES BEFORE TOOLS

A beginner with a scanner and no legal understanding is a risk to the client, the company and themselves. No trainee receives tool access or lab credentials until the quiz and acknowledgement are on file.

4.4 Code of Ethics (sign on Day 1)

1. I will test only with written authorisation and only inside the agreed scope.
2. I will protect client data and evidence as if it were my own most sensitive information.
3. I will use my skills to defend, never to harm, and I will report discoveries only to authorised contacts.
4. I will be honest in findings, including about what I do not know or did not test.
5. I will stop work and report if I see danger, an unexpected impact, or a doubt about authority.
6. I will not boast about, trade in or publish vulnerabilities or client details.
7. I will keep learning and ask for supervision when I reach the edge of my competence.
8. I will not discriminate against, harass or intimidate colleagues, clients or the public.
9. I will declare conflicts of interest, including any personal link to a client or target.
10. I accept that breaches of this code may lead to dismissal and legal action.

4.5 Secure workstation baseline

	Control	Required setting
☐	Operating system	Supported version, automatic updates on, local admin used only when needed

	Control	Required setting
☐	Disk encryption	Full-disk encryption enabled (BitLocker / FileVault / LUKS); recovery key stored in the company vault
☐	Endpoint protection	Company-approved antivirus/EDR active and updating
☐	Multi-factor authentication	Enabled on email, code hosting, password manager, VPN, cloud consoles; authenticator app or hardware key preferred over SMS
☐	Password manager	Company-approved; unique strong passwords; master secret protected with MFA
☐	Screen lock & firewall	Lock after 5 minutes or less; host firewall on
☐	Separate lab environment	Hypervisor (e.g. VirtualBox, VMware, KVM) with lab VMs only on a host-only network; no bridging to office or home LAN
☐	Browser profiles	One profile for work, one for lab testing tools; no saved work passwords in lab profile
☐	Backups & storage	Documents in approved encrypted storage; no client data on USB or personal cloud
☐	Tool inventory	Tools installed from official sources; versions recorded in the tool register

4.6 Accounts and access (least privilege)

System	Day 1 access	Granted later (needs Security Lead approval)
Email, chat, training portal	Standard user, MFA	—
Documentation repository	Read/write to training and internal docs	Engagement documents (no evidence)
Lab environment	Own local VMs only	Shared training range (VEL-owned)
Evidence store	**None**	Per engagement, A1 and above, time-limited
Client systems or credentials	**None**	Per engagement authorisation and authority level
Cloud consoles of VEL	None	Read-only roles after Level 3 and approval

4.7 Mentor, supervision and probation

- **Mentor:** a Consultant or Engineer at A2+ who meets the trainee weekly (30 minutes), reviews work products and signs weekly progress.
- **Observer rule:** trainees shadow real engagements as *silent observers* only after Day 30 and only if the client has been told a trainee is present.
- **Probation reviews:** Day 30, 60 and 90 with Security Lead; outcome recorded as *Proceed / Proceed with support plan / Extend / Stop*.
- **Escalation:** concerns about workload, ethics or a colleague's behaviour go to the mentor or Security Lead; retaliation is not tolerated.

4.8 Week 1 sign-off sheet

	Completed item	Trainee	Mentor	Security Lead
☐	Contract, NDA, Acceptable Use and Code of Ethics signed			
☐	Workstation baseline (4.5) verified			
☐	MFA and password manager active on all accounts			
☐	POL-SEC-001 acknowledged; legal and ethics quiz passed (100%)			
☐	Isolated lab network built and verified (Part 9 Phase A)			
☐	Lab Authorisation Record signed			
☐	Mentor 1:1 held; 90-day plan opened (Part 5)			

Authority level after Week 1: A0 (Trainee). Lab only. No client systems.

VEL SOFTWARE SOLUTIONS

Part 5 — 90-Day Training Roadmap

The roadmap takes a beginner through the seven training levels and eight practical projects in thirteen weeks. It assumes about 40 hours a week: roughly **35% learning, 45% hands-on lab, 10% documentation, 10% mentoring and review**. Pass marks and times are *suggested defaults* for management approval.

5.1 Roadmap overview

Phase	Levels covered	Practical projects	Gate at end
Phase 1 Days 1–30	Week 1 onboarding · L1 IT Fundamentals · L2 Linux & Windows Security	Project 1: Linux server hardening lab	**Gate 30:** fundamentals exam + Lab 01 report
Phase 2 Days 31–60	L3 Networking Security · L4 Cybersecurity Fundamentals	Project 2: Network security fundamentals lab · incident-response tabletop	**Gate 60:** networking and risk exam + tabletop role
Phase 3 Days 61–90	L5 Application Security · L6 Security Tools · L7 Frameworks	Projects 3–8: Juice Shop lab, secure API lab, dependency and secret scanning, cloud IAM assessment, monitoring dashboard, simulated client assessment	**Gate 90:** capstone report + oral review

5.2 Week-by-week plan

Week	Learning focus	Hands-on	Deliverable / check
Phase 1: Foundations (Days 1–30)			
1	Onboarding (Part 4): legal basis, ethics, workstation, lab	Isolated lab network; snapshots	Week 1 sign-off sheet; legal quiz 100%
2	L1: operating systems, networking basics, DNS, TCP/IP, HTTP/HTTPS, ports	Packet capture of *own* lab traffic; DNS lookups; port listing on own VM	Notes + 10-question quiz
3	L1: servers, databases, virtualisation, cloud fundamentals (IaaS/PaaS/SaaS, shared responsibility)	Install a web server and a small database in lab; free-tier cloud account with billing alerts (VEL-owned)	Architecture sketch of lab + cloud
4	L2: accounts, permissions, services, processes, logs, updates, firewall, SSH, Windows configuration, endpoint protection	**Project 1:** Linux hardening lab (Part 9)	**Gate 30**
Phase 2: Defence in depth (Days 31–60)			

Week	Learning focus	Hands-on	Deliverable / check
5	L3: firewalls, segmentation, routing, VPN	Segmented lab with two host-only networks; firewall rules between them	Network diagram + rule table
6	L3: TLS, DNS security, secure remote access, IDS/IPS fundamentals	**Project 2:** network security fundamentals lab: TLS configuration check on own server; simple IDS in lab	Lab 02 report
7	L4: CIA triad, authentication, authorisation, encryption, hashing, MFA	Hashing and encryption exercises; MFA setup on lab app	Concept map + quiz
8	L4: threats, vulnerabilities, risk, security controls, incident response (Part 8)	Risk scoring exercise; **tabletop** incident exercise	**Gate 60**
Phase 3: Applications, tools and frameworks (Days 61–90)			
9	L5: OWASP Top 10; authentication; access control; input validation; injection and XSS concepts; CSRF; SSRF; sessions	**Project 3:** OWASP Juice Shop learning lab (local container, isolated)	Lab 03 write-up of five issues with fixes
10	L5: API security; secure file upload; dependency security	**Project 4:** secure API assessment lab on a self-built training API	Lab 04 report
11	L6: tools, with legal and operational impact before use: ZAP, Burp (as licensed), Nmap, Wireshark, OpenVAS/Greenbone, Trivy, Gitleaks, Semgrep, SonarQube, Wazuh, Security Onion	**Project 5:** dependency and secret scanning on a deliberately flawed training repo	Tool register + Lab 05 report
12	L7: OWASP, NIST CSF, CIS Benchmarks, ISO/IEC 27001, MITRE ATT&CK, cloud best practice, data protection law	**Project 6:** cloud IAM configuration assessment (own cloud account, read-only role) · **Project 7:** security monitoring dashboard (Wazuh or similar, in lab)	Framework mapping sheet; Lab 06/07 outputs
13	Consolidation: reporting, remediation tracking, client communication	**Project 8:** complete simulated client assessment: authorisation pack to final report, using the lab as the "client"	**Gate 90:** capstone + oral review

5.3 Weekly rhythm

Day	Pattern
Monday	Plan the week with the mentor (30 min); read the module; check lab snapshots

Day	Pattern
Tuesday–Wednesday	Theory and guided practice; record commands, outputs and screenshots (sanitised)
Thursday	Independent lab or project work; ask questions early
Friday	Write up; update progress tracker; peer review; mentor sign-off

5.4 Gates and assessment standards

Gate	Assessment	Pass standard (suggested)	Authority after pass
Week 1	Legal and ethics quiz; policy acknowledgement; lab isolation check	100% on legal quiz; isolation verified	A0
Gate 30	Written exam on L1–L2 (40 questions); Lab 01 report reviewed; practical: harden and verify a fresh VM from a checklist	≥ 70% written; practical rubric ≥ 3/4 in every criterion; zero policy breaches	A0 → A0+ (may observe low-risk engagements)
Gate 60	L3–L4 exam; segmentation lab; tabletop participation; risk scoring exercise	≥ 70% written; practical ≥ 3/4	A0 → **A1 candidate**
Gate 90	Capstone assessment (Project 8) with report; oral defence of three findings and one limitation; QA review of capstone	Report passes QA; all Critical/High findings correctly rated; honest limitations stated	**A1** (supervised Tier 0–1) if Security Lead approves

Failing a gate is not a punishment: the trainee receives a support plan and re-attempts after 2 weeks. A policy breach (such as scanning a non-lab target) triggers an immediate Security Lead review regardless of scores.

5.5 Rubric for practical work (score 0–4 per criterion)

Criterion	0–1	3–4 looks like
Authorisation & scope	Missing	Lab Authorisation Record complete; targets verified before each tool run
Safety & rollback	None	Backups/snapshots taken; rollback proven; no outage caused
Technical accuracy	Wrong	Settings correct, verified with commands, explanation of *why*
Evidence quality	Poor	Before/after outputs; sanitised; hashes for key items; reproducible
Risk reasoning	Absent	Likelihood and impact stated; severity justified
Communication	Unclear	Clear, honest report a manager and an engineer can both use; limitations stated

5.6 Training project schedule and approvals

#	Project	Week	Environment (owned or intentionally vulnerable only)	Approver
1	Linux server hardening lab	4	Local VM on host-only network (Part 9)	Security Lead (lab record) + QA

#	Project	Week	Environment (owned or intentionally vulnerable only)	Approver
2	Network security fundamentals lab	6	Two-subnet virtual lab; own firewall VM	Security Lead
3	OWASP Juice Shop learning lab	9	Juice Shop container on localhost only	Security Lead
4	Secure API assessment lab	10	VEL-built training API on lab network	Security Lead
5	Dependency and secret scanning	11	Training repo with fake secrets and old dependencies	Security Lead
6	Cloud IAM configuration assessment	12	VEL-owned cloud sandbox account; read-only role; billing alerts	Security Lead + Cloud Engineer
7	Security monitoring dashboard	12	Lab SIEM/agents on lab VMs	Security Lead
8	Simulated client security assessment and report	13	Lab built to resemble a small-company estate; mock client documents	Security Lead + QA Reviewer

5.7 After day 90: continuing professional growth

- Months 4–6: join three supervised real engagements as A1 (Tier 0–1 tasks), write draft findings, attend client debriefs as observer.
- Months 6–12: pursue recognised external certifications or training suited to the chosen role. Certifications are the individual's earned credentials, listed in proposals only when actually held.
- Promotion to A2 requires at least three engagements with QA-reviewed work, a clean policy record, and Security Lead approval.
- Map roles to the NIST NICE framework to guide development and hiring.

Part 6 — Teaching Format and Module Catalogue

6.1 The 14-point teaching format

Every training module follows the same structure so learners know what to expect and reviewers know what to check.

#	Element	What it contains
1	Definition	What the topic is, in one or two plain sentences
2	Business purpose	Why a client or the company cares
3	Threat or risk addressed	What can go wrong without it
4	Prerequisites	Earlier modules, knowledge and access needed
5	Tool installation	Official source, version to record, licence
6	Safe configuration	Isolation, rate limits, authorisation and legal/operational impact
7	Step-by-step procedure	Numbered actions with exact commands
8	Expected output	What correct looks like
9	Verification	How to prove it worked
10	Common mistakes	Where beginners go wrong
11	Documentation	What to record, where to file it
12	Practical assignment	A task in an owned/vulnerable environment
13	Assessment	Questions and a practical rubric
14	Approval requirement	Who must sign before the learner proceeds, and what authority results

RULE FOR EVERY MODULE

Before any tool is used, the module states its **legal and operational impact**: what traffic it sends, what it may break, and what authorisation it needs. Learners must be able to explain this before they are allowed to run the tool.

6.2 Sample module M-L2-04: Linux accounts, permissions and SSH hardening

M-L2-04 · Level 2 · Linux and Windows Security · Lab-only (A0)	
1. Definition	Linux controls who can log in, what they can read, write or run through accounts, groups, file permissions and the SSH remote-login service. Hardening means removing unneeded access and tightening defaults.
2. Business purpose	Servers hold client data and run client applications. Weak accounts or open SSH are the commonest route to unauthorised access, outage and loss of trust.

3. Threat / risk	Password guessing against SSH, shared or stale accounts, over-permissive files, privilege escalation through misconfigured sudo or setuid programmes.
4. Prerequisites	M-L1 modules on operating systems, TCP/IP and ports; legal quiz passed; lab isolation verified.
5. Tool installation	Built into Ubuntu Server LTS: `openssh-server`, `sudo`, `ufw`. Record OS version (`lsb_release -a`) and OpenSSH version (`ssh -V`) in the tool register.
6. Safe configuration	Lab VM on host-only network only. **Snapshot first.** Keep a second console session open while changing SSH, so a mistake cannot lock you out.
7. Procedure	1. Review accounts: `getent passwd | awk -F: '$7 !~ /(nologin\|false)$/ {print $1,$7}'` 2. Find accounts with empty passwords: `sudo awk -F: '($2==""){print $1}' /etc/shadow` (expected: no output) 3. Review sudo rights: `sudo -l` and `getent group sudo` 4. Check file permissions on sensitive files: `ls -l /etc/shadow /etc/ssh/sshd_config` (shadow should not be world-readable) 5. List setuid files to understand them (read-only): `sudo find / -xdev -perm -4000 -type f -ls 2>/dev/null` 6. Create the SSH hardening drop-in `/etc/ssh/sshd_config.d/10-vel-hardening.conf` as in Part 9, step H3. 7. Validate syntax before applying: `sudo sshd -t` (no output means valid), then `sudo systemctl reload ssh`
8. Expected output	`sudo sshd -T` shows `permitrootlogin no`, `passwordauthentication no`, `maxauthtries 3`; key login works; password login is refused.
9. Verification	From the analyst VM: `ssh -o PreferredAuthentications=password -o PubkeyAuthentication=no labadmin@<lab-ip>` must return `Permission denied (publickey)`. Check `/var/log/auth.log` for the attempt.
10. Common mistakes	Disabling password login before a key works; editing the main file when an included file overrides it (first value wins); forgetting `sshd -t`; closing the only session.
11. Documentation	Change log (what, why, before/after), command output excerpts, rollback steps, tool register entry.
12. Practical assignment	Harden SSH on a fresh lab VM, then restore the snapshot and repeat from your own notes without the guide.
13. Assessment	Five written questions (why disable root login? what is "first value wins"? what does `sshd -t` do?); practical rubric (Part 5.5).
14. Approval	Mentor signs; module counts toward Gate 30. Authority remains A0.

6.3 Sample module M-L6-02: Nmap: safe, authorised network discovery

M-L6-02 · Level 6 · Security Tools · Lab-only until engagement-authorised (T1/T2)	
1. Definition	Nmap is a free network scanner that discovers hosts and reports open ports and services. It sends packets to the target; therefore it is an **active** tool.
2. Business purpose	Shows the client what is exposed to a network so unnecessary services can be closed and firewall rules verified.
3. Threat / risk	Unknown or forgotten services, misconfigured firewalls, shadow systems.

4. Prerequisites	M-L1 TCP/IP and ports; M-L3 firewalls; policy acknowledgement; for any non-lab target, a signed authorisation and A2 authority (T2).
5. Tool installation	Official project: **nmap.org**. Ubuntu: `sudo apt install -y nmap`. Record version with `nmap --version`. Licence: Nmap Public Source License (check terms for redistribution).
6. Legal & operational impact	Scanning someone else's network without permission may be illegal in your jurisdiction. Scans can trigger alarms, fill logs, and occasionally crash fragile devices. Use rate limits and agreed windows.
7. Procedure (lab)	1. Confirm the target IP is in your Lab Authorisation Record and is a VEL lab VM. 2. Host discovery on the lab subnet only: `nmap -sn 192.168.56.0/24` 3. Top-port scan with service versions: `nmap -sV --top-ports 1000 -oA lab01-baseline 192.168.56.101` 4. Compare scans before and after hardening using the saved `.nmap` files. 5. For firewalled targets, add `--max-retries 1` to avoid long waits.
8. Expected output	Before hardening: SSH plus any lab services listed as open. After hardening: only the intended ports open; others filtered.
9. Verification	Cross-check with `ss -tulpn` on the target. Anything Nmap reports but the host does not list is investigated (NAT, firewall, container).
10. Common mistakes	Scanning the whole home or office LAN; typing a wrong subnet; scanning a public IP "to test"; running aggressive scripts without approval; forgetting to save output.
11. Documentation	Command, version, time, target, output files (hash), person, approval reference.
12. Practical assignment	Write a one-page "scan plan" for the lab (targets, settings, impact, stop conditions), have it approved, then execute and report.
13. Assessment	Explain the impact of `-sn`, `-sV` and `--top-ports`; identify out-of-scope IPs in a sample list.
14. Approval	Security Lead approval of the scan plan for each non-lab use; Tier follows Part 3.

6.4 Sample module M-L6-05: Secret scanning with Gitleaks

M-L6-05 · Level 6 · Dependency and secret scanning · Lab (Project 5) then Tier 1	
1. Definition	Gitleaks searches files and Git history for strings that look like passwords, API keys or tokens.
2. Business purpose	Leaked credentials let outsiders sign in as the company. Finding them early lets the client revoke them.
3. Threat / risk	Hard-coded cloud keys, database passwords and tokens committed to repositories, including old commits.
4. Prerequisites	Git basics; M-L4 authentication concepts; for client repositories: authorisation naming the repositories and a read-only clone.
5. Tool installation	Official project: **github.com/gitleaks/gitleaks** (releases or package manager). MIT licence. Record version with `gitleaks version`.
6. Safe configuration	Run on a local read-only clone. Use `--redact` so reports do not store full secrets. Never paste real secrets in tickets or chat.

7. Procedure	1. Create a training repo with fake secrets only. For example, AWS's documented example key `AKIAIOSFODNN7EXAMPLE` in a file, committed, then deleted in a later commit. 2. Scan including history: `gitleaks detect --source . --redact --report-format json --report-path gitleaks-report.json` 3. Newer versions also provide `gitleaks git` and `gitleaks dir`; check `gitleaks --help` for your version. 4. Review each hit: real secret, example, or false positive? Record the decision. 5. Recommend: revoke and rotate the credential, remove from code, use a secrets manager, add a pre-commit scan.
8. Expected output	A report listing rule ID, file, commit and line, with the secret value redacted.
9. Verification	Delete the fake key from the current file: the history scan **still** finds it in the old commit. This shows why rotation matters more than deletion.
10. Common mistakes	Believing deletion fixes a leak; sharing the unredacted report; ignoring false positives without a recorded reason; testing a real secret to "see if it works" (this is unauthorised access).
11. Documentation	Finding record with commit hash, location, status (confirmed/false positive), recommended action; reports kept in restricted store.
12. Practical assignment	Scan the training repo, triage ten hits, write a one-page remediation plan including a pre-commit hook configuration.
13. Assessment	Why can a "deleted" secret still be dangerous? What must never be done with a discovered credential?
14. Approval	Lab: mentor sign-off. Client repos: Security Lead confirms the repository is named in scope (T1).

> **NEVER VALIDATE A DISCOVERED CREDENTIAL**
> Do not try a found key or password against a live system to see whether it works, unless the RoE explicitly permits that exact check. Report it, recommend revocation, and let the owner decide.

6.5 Module catalogue (Levels 1–7)

Every module follows the 14-point format. IDs follow `M-L{level}-{nn}`. "Env." shows where practice happens: **Lab** = isolated VM or container; **Cloud** = VEL-owned sandbox account; **Doc** = paper/exercise. No module in Levels 1–5 involves a client system.

ID	Topic	Core content	Env.	Week
Level 1 — IT Fundamentals				
L1-01	Operating systems	Kernel, users, processes, file systems; Windows, Linux, macOS differences	Lab	2
L1-02	Networking, TCP/IP, ports	OSI/TCP-IP layers, IP addressing, subnets, ports, TCP handshake	Lab	2
L1-03	DNS	Records, resolution, caching; `dig` / `nslookup` on own domains	Lab	2
L1-04	HTTP/HTTPS	Methods, headers, cookies, status codes, TLS handshake overview	Lab	2
L1-05	Servers and databases	Web and application servers; relational databases; backups	Lab	3

ID	Topic	Core content	Env.	Week
L1-06	Virtualisation and cloud	Hypervisors, containers, IaaS/PaaS/SaaS, shared responsibility	Lab/Cloud	3
Level 2 — Linux and Windows Security				
L2-01	Users and permissions	UIDs, groups, `chmod` / `chown`, sudo, least privilege	Lab	4
L2-02	Services and processes	`systemctl`, listening ports, reducing attack surface	Lab	4
L2-03	Logs and updates	journald, auth logs, auditd basics, patch cycles	Lab	4
L2-04	Firewall and SSH	UFW/nftables basics; SSH keys and hardening (sample module 6.2)	Lab	4
L2-05	Windows security configuration	Local policy, Defender, BitLocker, event logs, firewall profiles	Lab	4
Level 3 — Network Security				
L3-01	Firewalls and segmentation	Default-deny, zones, rule hygiene, review	Lab	5
L3-02	Routing, VPN and secure remote access	Site-to-site vs remote access VPN; MFA; bastion hosts	Lab	5
L3-03	TLS and certificates	Certificate chains, protocol versions, HSTS, expiry monitoring	Lab	6
L3-04	DNS security	DNSSEC overview, resolver hygiene, takeover risks	Lab	6
L3-05	IDS/IPS fundamentals	Signature vs anomaly; placement; tuning; alert fatigue	Lab	6
Level 4 — Cybersecurity Fundamentals				
L4-01	CIA and AAA	Confidentiality, integrity, availability; authentication, authorisation, accounting	Doc	7
L4-02	Encryption, hashing, MFA	Symmetric/asymmetric, password hashing, key management basics	Lab	7
L4-03	Threats, vulnerabilities and risk	Threat actors, CVE/CVSS, likelihood×impact, risk register	Doc	8
L4-04	Security controls and incident response	Preventive/detective/corrective; IR phases (Part 8)	Doc	8
Level 5 — Application Security (deliberately vulnerable apps only)				
L5-01	OWASP Top 10 overview	Categories, real-world causes, mitigations	Lab	9
L5-02	Authentication and session management	Password storage, MFA, cookie flags, session expiry	Lab	9
L5-03	Access control and input validation	Broken access control, injection and XSS **concepts**, output encoding, parameterised queries	Lab	9
L5-04	CSRF and SSRF	Anti-CSRF tokens, SameSite, egress allow-lists, metadata protections	Lab	9
L5-05	API security	Object-level authorisation, rate limiting, schema validation, key handling	Lab	10
L5-06	Secure file upload and dependencies	Type/size checks, storage outside web root, SCA, patching	Lab	10
Level 6 — Security Tools (legal and operational impact first)				
L6-01	OWASP ZAP and Burp Suite	Proxying own browser traffic; passive vs active scanning; licence terms	Lab	11
L6-02	Nmap and Wireshark	Discovery plan; packet capture of own lab traffic (sample module 6.3)	Lab	11
L6-03	OpenVAS / Greenbone	Scan policies, credentials, scan load, report triage	Lab	11

ID	Topic	Core content	Env.	Week
L6-04	Trivy, Semgrep, SonarQube	Image, dependency, IaC and code scanning; false-positive handling	Lab	11
L6-05	Gitleaks	Secret scanning; remediation (sample module 6.4)	Lab	11
L6-06	Wazuh, Security Onion, cloud-native tools	Agents, rules, dashboards, alert triage; AWS/Azure/GCP security services	Lab/Cloud	12
Level 7 — Security Frameworks				
L7-01	OWASP, NIST CSF, CIS Benchmarks	Using standards as checklists; mapping findings to controls	Doc	12
L7-02	ISO/IEC 27001 and MITRE ATT&CK	ISMS concepts; readiness vs certification; mapping detections to techniques	Doc	12
L7-03	Cloud best practices and data protection law	AWS, Azure, GCP guidance; privacy principles; role of counsel	Doc	12

Part 7 — Client Engagement Lifecycle (Stages 01–15)

Every client engagement follows the same fifteen stages. A stage is finished only when its output exists and its gate is signed. **No testing happens before Stage 02 is complete.**

7.1 Stage map

#	Stage	Key activities	Output	Gate
01	Client qualification	Collect company details, industry, systems, concerns, compliance needs, critical assets, business impact, budget, timeline	Qualification record	Lead: fit and capability
02	Written authorisation	Signed agreement, ownership confirmation, scope, methods, exclusions, window, emergency contact, stop-work, data handling	Authorisation pack (Part 3.3)	**Hard gate:** Lead + QA
03	Security discovery	Understand infrastructure, apps, APIs, cloud, network, databases, identity, controls, logging, backups, incident history	Architecture notes, interview records	Consultant
04	Asset inventory	Register of every asset (7.2)	`asset-inventory.csv`	Consultant + client owner
05	Threat model & risk assessment	Assets, threat actors, attack surfaces, trust boundaries, vulnerabilities, impact, existing controls, residual risk; documented method	Threat model, `risk-register.md`	Lead
06	Scope and cost approval	Scope, methodology, deliverables, timeline, personnel, tools, third-party costs, retest terms, exclusions, pricing; one-time vs managed fees separated	Proposal and SoW	Lead + client
07	Assessment environment	Approved workstation, secure OS, MFA, password manager, encrypted storage, approved VPN, logging, evidence management, tool versions	Environment checklist, tool register	Consultant + QA
08	Repository & documentation	Create project structure (7.3); restricted store for sensitive evidence	Project repository	Consultant
09	Security testing	Only RoE-permitted methods: configuration review, vulnerability, dependency, SAST, DAST, API, access control, authentication, cloud, network exposure	Raw results (restricted), test log	Consultant per tier
10	Vulnerability classification	Verify, de-duplicate, rate (7.4), assign owners and dates	Findings (confirmed, false-positive)	Lead (Critical/High)
11	Security hardening	Approved changes: MFA, least privilege, firewall, config, patching, TLS, encryption, headers, secrets, DB restrictions, logging, backups	Change records, rollback notes	Client system owner
12	Security QA	Verify fixes, no regressions, functionality, access restrictions, logging, configuration, backups, evidence integrity	QA checklist, retest results	QA + Lead
13	Reporting	Executive summary, scope, method, assets, findings, ratings, impact, plan, limitations, retest status	Final report (7.5)	Lead + QA

#	Stage	Key activities	Output	Gate
14	Client handover	Report, risk register, remediation tracker, configuration advice, evidence index, roadmap, retest plan, support proposal	Handover pack	Lead + client
15	Managed security	Monitoring, vulnerability tracking, patch verification, access reviews, configuration checks, incident coordination, monthly reports, periodic reassessment	Monthly report	Lead

7.2 Asset inventory fields

Field	Description / example
Asset ID	A-0001 (unique, never reused)
Asset type	Server, workstation, web app, API, database, cloud account, network device, SaaS
Owner / responsible team	Named person and team accountable for the asset
Environment	Production, staging, development, lab
IP or approved identifier	Address, hostname, URL or cloud resource ID as agreed
Business criticality	Critical / High / Medium / Low, with a one-line reason
Data classification	Public, internal, confidential, restricted (personal or regulated)
Technology	OS, framework, database, versions
Exposure	Internet-facing, internal, partner-only

7.3 Repository and documentation structure

```
cybersecurity-project/
├── README.md
├── docs/            scope.md  authorisation.md  rules-of-engagement.md  architecture.md
│                    methodology.md  risk-register.md  final-report.md
├── assets/          asset-inventory.csv  approved-targets.csv
├── assessments/     application/  api/  cloud/  network/  configuration/
├── evidence/        screenshots/  sanitised-logs/        (sanitised only)
├── findings/        confirmed/  false-positives/  remediation/
├── remediation/     recommendations.md  retest-results.md
├── policies/        access-control.md  data-handling.md  retention.md
└── reports/
```

NEVER COMMIT SENSITIVE MATERIAL

Passwords, tokens, customer data, raw scanner output with exploitable detail, and unsanitised evidence do **not** go into an ordinary Git repository. They live in the approved, restricted-access, encrypted evidence store. The repository holds only sanitised documents and references. Add secret scanning and a pre-commit hook to every project repository.

7.4 Finding record and rating

Finding field	Content
Finding ID / title	F-001 · short, neutral title

Finding field	Content
Affected asset	Asset ID(s) from the inventory
Description	What is wrong, in plain language
Evidence	Sanitised reference (file name, hash)
Severity / likelihood / business impact	Rating with reasoning (see below)
Reproduction conditions	Steps **within the authorised scope**, with the minimum detail needed to confirm; no weaponised exploit code
Remediation	Specific, testable fix; alternative mitigation
Owner / target date	Named client owner; date agreed
Status	Open, in progress, fixed, retested, accepted risk, false positive

Rating method. Where a CVE or weakness exists, record the **CVSS** base score and vector; then apply **business context** using a 5×5 likelihood × impact matrix. The final rating is the reasoned combination, never the scanner label alone.

Likelihood ↓ / Impact →	1 Minor	2 Moderate	3 Major	4 Severe	5 Critical
5 Almost certain	5	10	15	20	25
4 Likely	4	8	12	16	20
3 Possible	3	6	9	12	15
2 Unlikely	2	4	6	8	10
1 Rare	1	2	3	4	5

Rating	Score band	CVSS band (guide)	Suggested remediation target	Approval
Critical	16–25	9.0–10.0	7 days, interim mitigation immediately	Lead + second reviewer
High	10–15	7.0–8.9	30 days	Lead + second reviewer
Medium	5–9	4.0–6.9	90 days	Consultant
Low	1–4	0.1–3.9	180 days or next cycle	Consultant

Targets are suggested defaults; the client's risk appetite and contract prevail. Scanner alerts are labelled *unconfirmed* until manually verified (where safe) or confirmed from configuration evidence.

7.5 Final report outline

1. **Executive summary:** overall posture, top risks, decisions needed; no exploit detail.
2. Scope, authorisation reference and limitations (what was **not** tested).
3. Methodology and tools (with versions) and standards used (OWASP WSTG, CIS, NIST).
4. Assets assessed and risk summary chart.
5. Findings by severity, using the record in 7.4.
6. Business impact and risk ratings explained.
7. Remediation plan with owners, dates and quick wins.
8. Retest status and residual risk.
9. Restricted technical annex (need-to-know), evidence index.

HONEST LIMITATIONS

State the testing window, access level, excluded systems and the fact that an assessment is a point-in-time sample. Never claim the client is "secure" or "compliant". Say what was found, what was fixed and what remains.

7.6 Managed security: what is and is not included

Typically included (when contracted)	Not included unless explicitly agreed
• Vulnerability tracking and monthly rescans (T1/T2 per RoE) • Patch verification and configuration checks • Alert triage within stated business hours • Quarterly access reviews • Incident coordination and evidence guidance • Monthly security report; periodic reassessment	• **24/7 monitoring** (only if staffed and tooled to deliver it) • Hands-on forensic investigation or legal advice • Regulatory notification decisions • Fixing client application code • Third-party licence costs and cloud platform costs • Certification or independent audit

Pricing, margins and recurring revenue (hours, licences, storage, retests, support) are the subject of Module 3. One-time assessment fees and monthly managed fees are always quoted separately.

Part 8 — Security Incident Response

This part trains employees to respond calmly and consistently. The department **supports** the client's incident response; it does not make legal decisions and does not take actions outside its contract.

8.1 The six phases

#	Phase	Goal and key actions	Beginner's role (A0/A1)
1	**Preparation**	Contacts list, roles, tools, logging enabled, backups tested, playbooks, training and exercises	Know the escalation list; join tabletops
2	**Identification**	Detect and confirm an incident; record time, source, symptoms; assign severity	Report immediately; do not investigate alone
3	**Containment**	Limit spread without destroying evidence: isolate host, disable account, block address, as the client owner approves	Observe; take notes; follow instructions
4	**Eradication**	Remove cause: patch, remove malicious access, reset credentials, rebuild from trusted images	Support with checklists
5	**Recovery**	Restore services from verified backups; monitor closely; confirm normal operation	Support monitoring and verification
6	**Lessons learned**	Blameless review within 5 working days; update controls, runbooks and training	Contribute observations

8.2 Severity levels (suggested defaults)

Level	Definition	Examples	VEL response target*	Escalate to
SEV-1 Critical	Confirmed compromise of critical systems or personal data; ongoing active attacker; major outage	Ransomware; data exfiltration confirmed	Immediate (within 30 min of awareness)	Security Lead, Founder, client emergency contact
SEV-2 High	Likely compromise or serious exposure; limited impact so far	Compromised admin account; exposed database	Within 1 hour	Security Lead, client contact
SEV-3 Medium	Suspicious activity or policy violation, impact contained	Malware on one workstation; repeated failed logins	Same business day	Consultant / SOC
SEV-4 Low	Minor event, no evidence of impact	Blocked phishing email; scan noise	Within 2 business days	SOC Analyst

* Applies only within contracted hours. Managed-service contracts must state exact hours; do not promise round-the-clock cover that is not staffed.

8.3 Escalation procedure

1. **Detect and record:** note exact time (with time zone), what you saw, which asset, who told you.
2. **Tell your Security Lead at once** (phone, then message). Do not wait to be sure.
3. **Assign provisional severity** using 8.2; the Security Lead confirms.
4. **Notify the client's authorised contact** through the agreed channel; the PM keeps a timeline.
5. **Decide containment** with the client system owner. VEL recommends; the owner approves changes on their systems.
6. **Escalate to legal/compliance:** the Security Lead alerts the client's legal or compliance contact when personal data, regulated data or third parties may be affected.
7. **Record every action** in the incident log; close with a lessons-learned review.

8.4 Evidence preservation

	Requirement
☐	**Do not power off or rebuild** an affected system until the owner and Security Lead decide; memory and running state may be needed.
☐	**Work on copies.** Preserve originals; copy logs, images and files to the restricted store.
☐	**Hash and record.** Compute SHA-256 (`sha256sum file`) when collected; note collector, date/time, time zone and source.
☐	**Chain of custody:** every transfer logged (from, to, when, why). Fields in Appendix C.
☐	**Time synchronisation:** note clock offsets between systems so timelines are reliable.
☐	**Minimise personal data:** collect only what the investigation needs; restrict access.
☐	**No unauthorised "hack back"** or contact with the suspected attacker.

8.5 Client notification responsibilities

VEL does	VEL does not
• Tell the client's authorised contact promptly and factually • Provide timeline, facts known, unknowns, and recommended containment • Provide evidence in the agreed format • Remind the client to involve legal/compliance and, where applicable, their regulator-facing contact • Keep a written record of what was communicated and when	• **Decide whether a breach must be notified** to a regulator, customers or the public • Contact regulators, media or affected individuals on the client's behalf unless contractually instructed in writing • Give legal conclusions or speculate on cause or blame • Share incident details with anyone outside the authorised list

FOR AWARENESS ONLY: NOTIFICATION CLOCKS EXIST

Some laws and directions set short deadlines, for example CERT-In directions in India (six hours for specified cyber incident types), the DPDP Act, 2023, and GDPR's 72-hour rule for personal data breaches. **VEL never decides if or when these apply.** The Security Lead alerts the client and their counsel immediately so they can decide in time.

8.6 Incidents during an engagement

- If you find signs of a **real compromise**, treat it as a stop-work condition (Part 3.8): stop, preserve what you saw, call the Security Lead.
- If **your testing** causes an outage, stop, tell the client emergency contact at once, assist restoration and document honestly. Early honesty is protected.
- If you encounter **unexpected personal data**, stop, do not copy it, and report; the data handling agreement governs next steps.

8.7 Tabletop exercise 01 (Training Week 8)

Scenario (fictional): a small accounting firm reports that three staff cannot open files and a note demands payment. One staff member says they clicked a link yesterday.

#	Questions the group must answer
1	What do we know, and what do we not know? What is the provisional severity and why?
2	Whom do we tell first, second and third? Who approves containment?
3	What evidence must be preserved before any action, and who may touch the machines?
4	Which backups exist, and how would we verify them before restoring?
5	What do we say to the client contact, and what must we **not** say (legal decisions, blame, payment advice)?
6	What lessons and control changes would we recommend afterwards?

Scoring: participants are assessed on following escalation, evidence discipline, clear communication and respecting limits (Part 5.5).

Part 9 — Lab 01: Isolated Linux Server Hardening Lab

Lab ID	LAB-01 · Training Project 1 · Roadmap Week 4 · Level 2
Environment	VEL-owned virtual machines on a **host-only** network. No client systems. No internet-exposed services.
Authority required	A0 (trainee) with a signed Lab Authorisation Record
Estimated time	12–16 hours over 5 days
Approval to complete	Mentor review, QA Reviewer check of report, Security Lead sign-off (Gate 30)

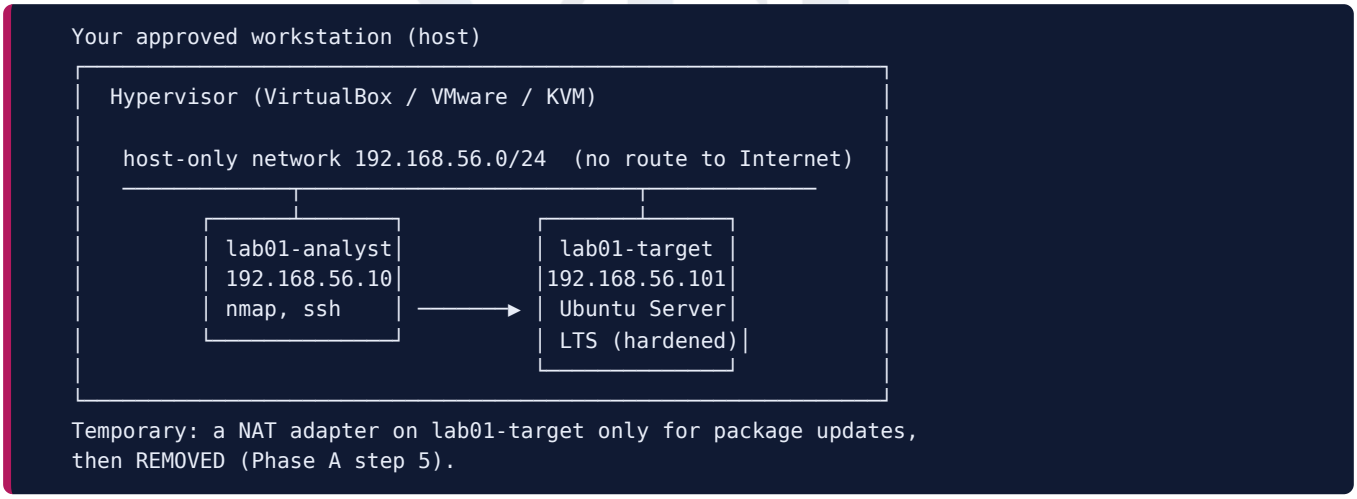
LAB RULE

Every IP address you scan, probe or log in to in this lab must be one of your **own lab VMs**, listed in your Lab Authorisation Record. If a command could reach any other address, stop and ask.

9.1 Objectives and learning outcomes

- Build an isolated lab and prove that it is isolated.
- Capture a baseline of a default Linux server and identify its weaknesses.
- Apply ten hardening controls safely, with backups, verification and rollback.
- Compare before and after results and write an evidence-based hardening report.
- Practise the habit: **authorise, snapshot, change, verify, document**.

9.2 Lab topology



Addresses are examples. VirtualBox's default host-only range is 192.168.56.0/24; use your hypervisor's real values and put **your** addresses in the Lab Authorisation Record.

VM	Specification	Purpose
lab01-target	Ubuntu Server LTS (current supported release), 2 vCPU, 2 GB RAM, 20 GB disk, OpenSSH installed during setup	The server you will harden

VM	Specification	Purpose
lab01-analyst	Ubuntu Server or Desktop LTS, 1–2 vCPU, 2 GB RAM, with `nmap` and `ssh`	Plays the role of an outside observer on the lab network

9.3 Prerequisites and tool register

- Week 1 sign-off complete (legal quiz 100%, POL-SEC-001 signed).
- Modules L1-01 to L1-06 and L2-01 to L2-04 studied.
- Free software only. Record each tool, version, source and licence in the tool register: hypervisor, Ubuntu Server LTS, OpenSSH, UFW, fail2ban, auditd, nmap, optional Lynis.

9.4 Phase A: Authorise and isolate (Day 1)

1. **Sign the Lab Authorisation Record** (Appendix C) listing VM names, IPs, purpose and dates. The Security Lead countersigns.
2. **Create the host-only network** in your hypervisor. Do **not** choose "bridged" for any lab VM.
3. **Install lab01-target and lab01-analyst.** Create an admin user `labadmin` (not `root`); install OpenSSH server when asked.
4. **Update the target** while the temporary NAT adapter is attached:

```
sudo apt update && sudo apt full-upgrade -y
sudo reboot
```

5. **Remove the NAT adapter** from lab01-target (VM powered off, then in the hypervisor network settings). Boot the VM.
6. **Prove isolation** on lab01-target:

```
ip -br addr                 # only the host-only address (e.g. 192.168.56.101)
ip route                    # no default route
ping -c 2 -W 2 1.1.1.1      # must FAIL (network unreachable / 100% loss)
ping -c 2 192.168.56.10     # must succeed (analyst VM)
```

7. **Take snapshot "S0-clean-isolated"** of both VMs.

> **Isolation check passed only if the target cannot reach the Internet and no lab VM is bridged to your LAN.**

9.5 Phase B: Baseline (Day 2)

Record the "before" state. Save outputs to `lab01/evidence/baseline/` on your workstation (no real data; safe to store in the training repo).

1. **Configuration backup** on the target:

```
sudo tar czf /var/backups/etc-baseline-$(date +%F).tgz /etc
sha256sum /var/backups/etc-baseline-*.tgz | tee ~/etc-baseline.sha256
```

2. **System facts:**

```
lsb_release -a; uname -r; ssh -V
getent passwd | awk -F: '$7 !~ /(nologin|false)$/ {print $1,$7}'
sudo awk -F: '($2==""){print $1}' /etc/shadow
sudo ss -tulpn
systemctl list-unit-files --type=service --state=enabled
sudo sshd -T | grep -Ei
'^(permitrootlogin|passwordauthentication|maxauthtries|x11forwarding|logingracetime)'
sudo ufw status verbose
```

3. **External view** from lab01-analyst (own lab IP only):

```
nmap -sV --top-ports 1000 -oA ~/lab01-baseline 192.168.56.101
```

4. **Optional audit score.** On the target:

```
sudo apt install -y lynis    # temporary NAT needed, or use an offline package
sudo lynis audit system
```

Note the "Hardening index" and warnings. The audit is read-only.

5. **Write down weaknesses** you see (for example: password login enabled, no firewall, unnecessary services) as draft findings with a likelihood and impact rating (Part 7.4).

6. **Snapshot "S1-baseline"**.

If the target has no internet, install packages needed for later steps (`ufw fail2ban auditd libpam-pwquality unattended-upgrades lynis`) before removing the NAT adapter, or reattach NAT briefly; remove it again and re-run the isolation check.

9.6 Phase C: Hardening controls H1–H10 (Days 2–4)

SAFETY RULES FOR EVERY STEP

- Keep a **second console session** (hypervisor console) open when you change SSH or the firewall.
- Change **one control at a time**, verify, then record in the change log.
- If anything breaks, **revert the snapshot** or the specific file, and note why.

SOFTWARE SOLUTIONS

H1 · Patching and automatic security updates

```
sudo apt install -y unattended-upgrades
sudo dpkg-reconfigure -plow unattended-upgrades      # choose Yes
sudo unattended-upgrade --dry-run --debug | tail -n 5
```

Why: known vulnerabilities are the easiest way in. **Verify:** `systemctl is-enabled unattended-upgrades` returns `enabled`; the dry run completes without errors. **Rollback:** `sudo apt remove unattended-upgrades`.

H2 · Accounts and password quality

```
sudo passwd -l root                                  # lock the root password (sudo still works)
sudo apt install -y libpam-pwquality
sudo sed -i 's/^# *minlen.*/minlen = 14/' /etc/security/pwquality.conf
grep -E '^minlen' /etc/security/pwquality.conf
sudo awk -F: '($2==""){print $1}' /etc/shadow         # expect no output
```

Why: limits shared or guessable credentials. **Verify:** `sudo passwd -S root` shows `L` (locked); no accounts with empty passwords. **Decision log:** list each remaining login-capable account with owner

and purpose; remove or lock any without one.

H3 · SSH: key login only, no root, limited attempts

On **lab01-analyst** create a key and copy it:

```
ssh-keygen -t ed25519 -C "lab01-analyst"
ssh-copy-id labadmin@192.168.56.101
ssh labadmin@192.168.56.101        # must log in with the key
```

On **lab01-target** create the drop-in file (it must sort *before* cloud-init files, because the first value wins):

```
sudo tee /etc/ssh/sshd_config.d/10-vel-hardening.conf >/dev/null <<'EOF'
PermitRootLogin no
PasswordAuthentication no
KbdInteractiveAuthentication no
PubkeyAuthentication yes
MaxAuthTries 3
LoginGraceTime 30
X11Forwarding no
AllowUsers labadmin
EOF
sudo sshd -t && sudo systemctl reload ssh
```

Verify (from analyst): `ssh -o PreferredAuthentications=password -o PubkeyAuthentication=no labadmin@192.168.56.101` must give `Permission denied (publickey)`. On target: `sudo sshd -T | grep -Ei '^(permitrootlogin|passwordauthentication|maxauthtries|allowusers)'`. **Rollback:** `sudo rm /etc/ssh/sshd_config.d/10-vel-hardening.conf && sudo systemctl reload ssh` (use the hypervisor console if SSH is locked).

H4 · Host firewall (UFW), default deny

```
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow from 192.168.56.0/24 to any port 22 proto tcp
sudo ufw logging on
sudo ufw enable
sudo ufw status verbose
```

Always add the SSH allow rule before enabling. Verify: status shows `Status: active`, default `deny (incoming)`, and port 22 allowed from the lab subnet. **Rollback:** `sudo ufw disable`.

H5 · Reduce attack surface

```
sudo ss -tulpn                                    # what listens?
systemctl list-unit-files --type=service --state=enabled
# Only after confirming a service is unneeded and recording the decision:
sudo systemctl disable --now <service-name>
```

Why: every listening service is a possible weakness. **Verify:** only SSH (port 22) listens on the lab address, apart from local-only services such as the system resolver on 127.0.0.53. Never disable a service you cannot explain.

H6 · Brute-force protection (fail2ban)

```
sudo apt install -y fail2ban
sudo tee /etc/fail2ban/jail.d/vel-sshd.local >/dev/null <<'EOF'
[sshd]
enabled  = true
backend  = systemd
maxretry = 4
findtime = 10m
bantime  = 1h
EOF
sudo systemctl enable --now fail2ban
sudo systemctl restart fail2ban
sudo fail2ban-client status sshd
```

Verify: the jail `sshd` is listed and active. *Optional, own lab only:* from the analyst VM, try logging in as a non-existent user a few times (`ssh nosuchuser@192.168.56.101`); check `sudo fail2ban-client status sshd` for a banned address, then unban with `sudo fail2ban-client set sshd unbanip 192.168.56.10`.

H7 · Audit logging (auditd)

```
sudo apt install -y auditd
sudo tee /etc/audit/rules.d/vel-lab01.rules >/dev/null <<'EOF'
-w /etc/passwd -p wa -k identity
-w /etc/shadow -p wa -k identity
-w /etc/sudoers -p wa -k sudoers
-w /etc/sudoers.d/ -p wa -k sudoers
-w /etc/ssh/sshd_config -p wa -k sshd
-w /etc/ssh/sshd_config.d/ -p wa -k sshd
EOF
sudo augenrules --load
sudo auditctl -l
```

Verify: create and remove a harmless file `sudo touch /etc/ssh/sshd_config.d/zz-test.conf; sudo rm /etc/ssh/sshd_config.d/zz-test.conf`, then `sudo ausearch -k sshd -ts recent` shows the events. **Why:** you cannot investigate what you did not log.

H8 · Time synchronisation and kernel network settings

```
timedatectl                                          # System clock synchronized: yes
sudo tee /etc/sysctl.d/90-vel-lab01.conf >/dev/null <<'EOF'
net.ipv4.conf.all.rp_filter = 1
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.all.send_redirects = 0
net.ipv6.conf.all.accept_redirects = 0
net.ipv4.tcp_syncookies = 1
net.ipv4.conf.all.log_martians = 1
kernel.randomize_va_space = 2
EOF
sudo sysctl --system | tail -n 5
```

Verify: `sysctl net.ipv4.tcp_syncookies kernel.randomize_va_space` returns the values set. **Note:** accurate time makes logs trustworthy. Without the NAT adapter, time sync may need the hypervisor's guest tools or a lab NTP source; record what you used.

H9 · File permissions and privileged programmes

```
ls -l /etc/shadow /etc/passwd /etc/ssh/sshd_config
sudo find / -xdev -type f -perm -0002 -ls 2>/dev/null       # world-writable files
sudo find / -xdev -perm -4000 -type f -ls 2>/dev/null      # setuid programmes (review only)
chmod 700 ~/.ssh && chmod 600 ~/.ssh/authorized_keys
```

Verify: no unexpected world-writable files; each setuid programme is a normal system component you can explain. **Do not** remove setuid bits you do not understand; note them as questions for your mentor.

H10 · Backup and configuration baseline

```
sudo tar czf /var/backups/etc-hardened-$(date +%F).tgz /etc
sudo sha256sum /var/backups/etc-hardened-*.tgz | tee ~/etc-hardened.sha256
```

Verify: extract both archives into separate folders and run `diff -rnu baseline/etc hardened/etc`; every difference corresponds to a change-log entry. Take snapshot **"S2-hardened"**. **Proof of rollback:** restore **S1-baseline**, confirm the weak settings are back, then restore S2.

9.7 Phase D: Verify and compare (Day 5)

1. Repeat all baseline commands from 9.5 and save to `evidence/after/`.
2. From lab01-analyst scan again (own lab IP only):

   ```
   nmap -sV --top-ports 1000 --max-retries 1 -oA ~/lab01-after 192.168.56.101
   ```

   Expected: 22/tcp open (OpenSSH); everything else filtered or closed.
3. Compare scans: `ndiff ~/lab01-baseline.xml ~/lab01-after.xml` (installed with Nmap).
4. Re-run Lynis if used; record the new hardening index and remaining suggestions.
5. Run a **functionality check**: legitimate admin login by key works; updates install; logs are written; time is synchronised.

Expected results summary

Control	Before (typical default)	After (target state)
SSH password login	Enabled	Disabled; key only; root login disabled
Host firewall	Inactive	Active, default deny, SSH from lab subnet only
Open ports (external view)	22/tcp plus any default services	22/tcp only
Updates	Manual	Automatic security updates configured
Brute-force protection	None	fail2ban sshd jail active
Audit logging	No file/identity watches	auditd rules loaded for identity and SSH files
Config backup & rollback	None	Hashed archives and tested snapshot restore

9.8 Common mistakes and troubleshooting

Symptom	Likely cause / fix
Cannot SSH after H3	Key not copied or `AllowUsers` wrong. Use the hypervisor console, remove the drop-in, reload, repeat step by step.
`sshd -T` still shows `passwordauthentication yes`	Another file set it first. List `/etc/ssh/sshd_config.d/`; your file must sort earlier (e.g. `10-`).
Locked out after enabling UFW	SSH allow rule missing or wrong subnet. Console: `sudo ufw allow from 192.168.56.0/24 to any port 22 proto tcp`.
Nmap scan is very slow after the firewall	Dropped packets cause retries. Use `--top-ports 1000 --max-retries 1`.
Packages fail to install	No network (NAT removed). Install needed packages first, or briefly re-attach NAT and re-check isolation.
fail2ban shows no jail	Check `/etc/fail2ban/jail.d/vel-sshd.local` spelling and `sudo journalctl -u fail2ban -n 50`.
Scanned an IP not in your record	**Stop. Report to the Security Lead immediately** (Part 3.11).

9.9 Deliverables: the Lab 01 hardening report

1. **Lab Authorisation Record** (signed) and isolation proof.
2. **Baseline findings**: at least five weaknesses with severity reasoning.
3. **Change log** table: control, command/file, reason, verification, rollback, time.
4. **Before/after evidence** (sanitised) and the Nmap comparison.
5. **Rollback proof** (snapshot restore) and functionality test result.
6. **Residual risks and next steps** (for example centralised logging, MFA for SSH, CIS Benchmark review).
7. **Reflection**: what went wrong, what you would do differently, any near-miss against policy.

> **REFERENCE BENCHMARK**
> After completing the lab, compare your choices with the CIS Benchmark for your Ubuntu release and the NIST Cybersecurity Framework "Protect" outcomes. Check the CIS terms of use: some CIS content and tools may require membership for commercial use.

9.10 Assessment and approvals

Criterion	Maximum score 4: evidence of
Authorisation & isolation	Signed record; isolation proven before any scan; only listed IPs targeted
Baseline quality	Complete, reproducible, correctly interpreted
Hardening correctness	All ten controls applied, each verified by output
Safety	Backups, snapshots, rollback demonstrated; no lockout without recovery
Documentation	Clear change log; honest limitations; sanitised evidence
Understanding	Can explain *why* each control matters and its side effects

Sign-off	Name	Signature	Date
Trainee: submitted			
Mentor: practical reviewed			
QA Reviewer: report checked			
Security Lead: Lab 01 approved (counts toward Gate 30)			

Lab 01 complete does not grant client-system authority. Authority remains A0 until Gate 90.

Appendices

Appendix A: Official sources and references

Use **current** official guidance and applicable law. Standards change: check the version date before quoting a control or clause in a client document.

Source	Link	Used for
OWASP	https://owasp.org/	Top 10, ASVS, cheat sheets, Juice Shop
OWASP Web Security Testing Guide	https://owasp.org/www-project-web-security-testing-guide/	Web and API testing methodology
NIST Cybersecurity Framework	https://www.nist.gov/cyberframework	Govern, Identify, Protect, Detect, Respond, Recover outcomes
CIS (Center for Internet Security)	https://www.cisecurity.org/	CIS Benchmarks and Controls (check licence terms)
MITRE ATT&CK	https://attack.mitre.org/	Adversary behaviour for detection mapping
NIST NICE Framework	https://www.nist.gov/itl/applied-cybersecurity/nice	Role and skills mapping
AWS Security	https://docs.aws.amazon.com/security/	AWS best practice and shared responsibility
Microsoft Security	https://learn.microsoft.com/security/	Azure and Windows security guidance
Google Cloud Security	https://cloud.google.com/security	GCP security guidance

Tool project sites (verify downloads from these official sources)

Tool	Official site
OWASP ZAP	https://www.zaproxy.org/
Burp Suite (PortSwigger; licence as purchased or Community edition terms)	https://portswigger.net/burp
Nmap	https://nmap.org/
Wireshark	https://www.wireshark.org/
Greenbone / OpenVAS	https://www.greenbone.net/
Trivy	https://github.com/aquasecurity/trivy

Tool	Official site
Gitleaks	https://github.com/gitleaks/gitleaks
Semgrep	https://semgrep.dev/
SonarQube	https://www.sonarsource.com/products/sonarqube/
Wazuh	https://wazuh.com/
Security Onion	https://securityonionsolutions.com/
OWASP Juice Shop	https://owasp.org/www-project-juice-shop/

Check each tool's current licence and edition limits before using it commercially. Record the licence in the tool register.

Appendix B: Glossary

Term	Meaning
Asset	Anything of value to protect: system, data, application, account, process
Authorisation (testing)	Written permission from the asset owner defining scope, methods and time
Attack surface	All points where an unauthorised party could try to enter or extract data
CIA triad	Confidentiality, integrity, availability
CVE / CVSS	Public vulnerability identifier / standard severity scoring system
DAST / SAST / SCA	Testing a running app / analysing source code / checking third-party components
EDR	Endpoint detection and response software
False positive	A scanner alert that is not a real vulnerability
Hardening	Reducing a system's attack surface by tightening configuration
IAM	Identity and access management
IDS / IPS	System that detects / detects and blocks suspicious network activity
Least privilege	Giving only the access needed to do the job
MFA	Multi-factor authentication: two or more kinds of proof of identity
Residual risk	Risk that remains after controls are applied
RoE	Rules of Engagement, the signed testing rules for an engagement
SIEM	Security information and event management: central log analysis
Snapshot	Saved state of a virtual machine that can be restored
SSRF / CSRF / XSS	Server-side request forgery / cross-site request forgery / cross-site scripting (concepts taught on vulnerable training apps)
Stop-work	Immediate halt of testing under agreed conditions
Threat model	Structured analysis of what can go wrong, who might cause it, and what stops it
Tier (T0–T3)	VEL risk classification of testing activity
Trust boundary	Line where data or control passes between zones of different trust

Appendix C: Ready-to-copy templates

C1. Lab Authorisation Record

Trainee / Lab ID	_____ / LAB-___
Purpose	Training exercise: _____
Owned environment	VEL-owned VMs on host-only network _____ (no bridged adapter)
Permitted targets	VM name / IP: _____ ; _____
Permitted tools	_____
Dates	From _____ to _____
Isolation proof attached	☐ Network config ☐ Internet-unreachable test ☐ Snapshot
Signatures	Trainee _____ Mentor _____ Security Lead _____ Date _____

C2. Test authorisation (client engagement): minimum content

Client / legal entity	_____ · authorised signatory (name, title)
Ownership statement	"The client owns or controls the assets listed and may authorise their testing."
Targets / exclusions	See approved-targets.csv (attached)
Methods & tier	☐ T0 ☐ T1 ☐ T2 ☐ T3 (named activity: _____)
Window	_____ to _____ (time zone) · blackout: _____
VEL testers	_____ (authority level) · source IPs: _____
Emergency contacts	Client: _____ phone _____ · VEL: _____ phone _____
Stop-work	As Part 3.8, plus: _____
Data handling	Data types: ____ · storage: ____ · retention: ____ · deletion proof: ☐
Signatures	Client _____ VEL Security Lead _____ Date _____

C3. Finding record

```
ID: F-___          Title: _____________________   Date: ________
Asset(s): A-____   Environment: ______   Status: Open / Fixed / Retested / Accepted / False
positive
Description: _____________________________________________
Evidence ref (file + SHA-256): ___________________________
CVSS (vector/score, if applicable): _______   Likelihood (1-5): __  Impact (1-5): __  Rating:
_______
Business impact: _____________________________________________
Reproduction conditions (within scope, minimum detail): ________
Remediation: _____________________________________________
Owner: __________  Target date: ________
Author: ________   Reviewer (second person, required for Critical/High): ________
```

C4. Chain-of-custody log

Item ID	Description / source	Collected by	Date/time (TZ)	SHA-256	Transfer (from → to, why)

C5. Change log (hardening)

#	Control	Change (command / file)	Reason	Verification	Rollback	Approver

C6. Tool register

Tool	Version	Source / hash	Licence	Installed on	Approved by

Appendix D: Beginner quick-reference card

Before I run anything, I ask…	If the answer is "no" or "not sure"
Is this target in my signed authorisation or Lab record?	Stop. Do not run it.
Is today and now inside the permitted window?	Stop.

Before I run anything, I ask…	If the answer is "no" or "not sure"
Does my authority level allow this tier?	Ask the Security Lead.
Do I know what traffic this will send and what it could break?	Read the module; ask the mentor.
Have I backed up and can I roll back?	Take the snapshot or backup first.
Where will the output be stored, and does it contain secrets?	Use the restricted store; redact.

Appendix E: What comes next (module plan)

The department is built one module at a time. Each module is released only after the previous one is reviewed and approved.

Module	Content	Gate to start
1 (this)	Handbook, onboarding, responsibility matrix, 90-day roadmap, testing policy, Lab 01	Management approval of POL-SEC-001
2	Level 1–2 full lessons (14-point format), Windows hardening lab, Lab 02 network fundamentals	Module 1 approved
3	Commercial engine: proposal, SoW, pricing model (consultant and reviewer hours, licences, storage, retests), margins and recurring revenue	Module 1 approved; insurance confirmed
4	Level 3–4 lessons, incident response runbooks, tabletop kit	Gate 60 design agreed
5	Level 5 appsec: Juice Shop and secure API labs, secure coding guidance	Lab host approved
6	Level 6–7: tool playbooks, cloud IAM lab, monitoring dashboard, frameworks mapping	Tool licences recorded
7	Complete simulated client assessment (Project 8) and report templates	Modules 1–6 complete

Appendix F: Document approval and revision history

Version	Date	Change	Author
1.0 draft	4 Nov 2026	Module 1 foundation pack issued for management approval	V. LOKESHWARAN

Approval	Name	Signature	Date
Founder			
Security Lead			
Legal counsel review (policy and templates)			

This handbook is an internal training and operating document. It is not legal advice and does not constitute certification, accreditation or assurance of any client's security.